

CAPSTONE PROJECT REPORT

Report 1 – Project Introduction

Table of Contents

I. Record of Changes.....	3
II. Project Introduction.....	4
1. Overview.....	4
1.1 Project Information.....	4
1.2 Project Team.....	4
2. Product Background.....	4
2.1 ReactJS.....	4
2.2 Tailwind CSS.....	5
2.3 Recharts.....	6
2.4 Node.js.....	6
2.5 NestJS.....	7
2.6 REST API.....	8
2.7 WebSocket.....	8
2.8 PostgreSQL.....	9
2.9 Elasticsearch.....	10
2.10 Ollama.....	10
2.11 Docker.....	11
3. Existing Systems.....	12
3.1 Eramba.....	12
3.2 Wazuh.....	14
3.3 Splunk Enterprise Security.....	15
4. Business Opportunity.....	17
5. Software Product Vision.....	18
6. Project Scope & Limitations.....	19
6.1 Major Features.....	19
6.2 Limitations & Exclusions.....	20
7. References.....	21

I. Record of Changes

Date	A* M, D	In charge	Change Description
07/09/2026	A	Pham Van Hoai	1. Overview, 2.Product Background, 7. References
08/09/2026	A	Doan Thi Yen Nhi	3. Existing Systems, 7. References
09/09/2026	A	Le Dang Khoa	4. Business Opportunity, 7. References
09/09/2026	A	Nguyen Chi Duong	5. Software Product Vision 7. References
10/09/2026	A	Le Thinh	6. Project Scope & Limitations, 7. References
10/09/2026	M	Nguyen Chi Duong	1. Overview
11/09/2026	A	Pham Van Hoai	2.Product Background: 2.11 Docker
12/09/2026	M	Le Thinh	7. References
13/09/2026	M	Le Dang Khoa	2.Product Background, 3. Existing Systems, 6. Project Scope & Limitations, 7. References
13/09/2026	M	Doan Thi Yen Nhi	4. Business Opportunity, 5. Software Product Vision, 6. Project Scope & Limitations, 7. References

*A - Added M - Modified D - Deleted

II. Project Introduction

1. Overview

1.1 Project Information

- Project name: Enterprise Information Security Risk Management Platform with AI-based Anomaly Detection
- Project code: SecuraAI
- Group name: SEP490 - G2
- Software type: Web

1.2 Project Team

Full Name	Role	Email	Mobile
Luong Hoang Huong	Lecturer	huonglh3@fe.edu.vn	0941666545
Pham Van Hoai	Leader	hoaipvce181744@fpt.edu.vn	0333622144
Le Thinh	Member	thinhlc180136@fpt.edu.vn	0913987736
Le Dang Khoa	Member	khoaldce181030@fpt.edu.vn	0855001070
Doan Thi Yen Nhi	Member	nhidtyce180492@fpt.edu.vn	0794910768
Nguyen Chi Duong	Member	duongncce180374@fpt.edu.vn	07633388151

2. Product Background

The proposed platform addresses a fragmented security management environment in which risk management, compliance, asset management, and security monitoring may be handled through separate tools.. This fragmented approach makes security monitoring, risk assessment, and incident response difficult and time-consuming. The proposed Enterprise Information Security Risk Management Platform provides a centralized web-based solution that integrates risk management, compliance, incident handling, security awareness training, and AI-based anomaly detection. Employees can easily report incidents, access policies, and participate in security training, while Security Officers can monitor assets, assess risks, investigate AI-generated alerts, and respond to incidents more efficiently. Administrators can manage users, permissions, integrations, and system audit logs, while executives and auditors can review dashboards, compliance reports, risk trends, and approval requests. By combining GRC functions with explainable AI and automated anomaly detection, the system helps organizations improve security visibility, reduce manual monitoring effort, and make faster and more informed security decisions.

2.1 ReactJS

ReactJS is a powerful JavaScript library specialized in building highly interactive user interfaces through a component-based architecture [1]. In the SecuraAI project, ReactJS plays a core role in developing customized web interfaces for various roles, including administrators, security officers, regular employees, and executives. The reusability of UI components not only optimizes development time [1], but the React's component-based architecture and rendering optimizations can support responsive interfaces, while additional techniques such as pagination, virtualization, and memoization may be required for large volumes of alert data. Furthermore, the seamless integration of ReactJS with backend services via REST APIs creates a smooth data flow, making it highly suitable for Single Page Applications and the full-stack development ecosystem.

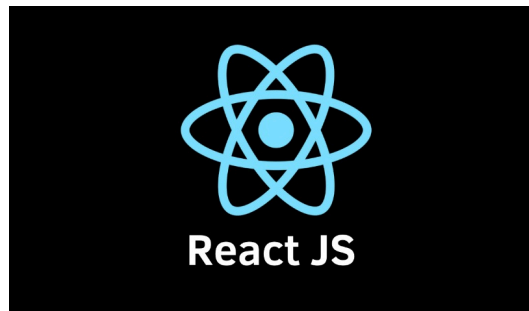


Figure 1: ReactJS¹

Strengths [1]:

- Component-based architecture
- Reusable UI components
- Efficient rendering
- Large development ecosystem
- Suitable for Single Page Applications
- Easy integration with REST APIs

Weaknesses [17]:

- Steep learning curve for advanced concepts
- Requires additional libraries for routing and state management
- High pace of ecosystem development

2.2 Tailwind CSS

Tailwind CSS is a utility-first CSS framework that provides an optimized approach to designing highly customizable and responsive user interfaces [2]. Instead of writing complex, independent CSS files, Tailwind offers predefined classes that are applied directly to the HTML structure, significantly accelerating rapid UI development [2]. In a security management system containing multiple analytical dashboards, Tailwind ensures consistent interface styling across the entire platform and reduces repetitive CSS code [2], while integrating perfectly with the ReactJS component architecture.



Figure 2: Tailwind CSS²

Strengths [2]:

- Rapid UI development
- Responsive design support
- Highly customizable
- Consistent interface styling
- Easy integration with ReactJS
- Reduces repetitive CSS code

¹https://codelearn.io/sharing/viet-ung-dung-dau-tien-voi-reactjs?srsId=AfmBOopl6dY4a6YzrBfo2lDNouQvKXZnLn3JSfaHlgjTi_JgHTCsI91

² <https://homenest.com.vn/gioi-thieu-css-frameworks-tailwind-css-va-ung-dung>

Weaknesses [2]:

- Cluttered HTML with multiple utility classes
- Learning curve for memorizing class names
- Lack of pre-built UI components

2.3 Recharts

Recharts is a charting library built specifically for the React ecosystem [3], playing a crucial role in visualizing complex system data. This platform is utilized to construct charts displaying risk levels, security incident volumes, compliance statuses, and alerts from the AI system. Thanks to its simple, reusable APIs and support for multiple chart types [3], Recharts is an ideal tool for developing responsive chart components that assist executives in easily monitoring security dashboards [3].

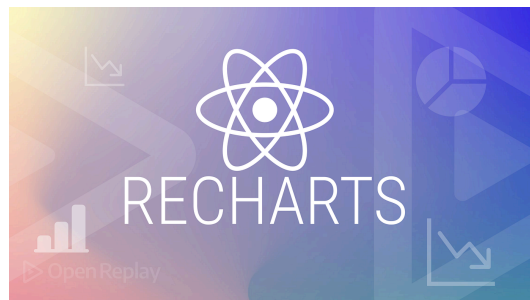


Figure 3: Recharts³

Strengths [3]:

- Easy integration with ReactJS
- Responsive chart components
- Simple and reusable APIs
- Suitable for dashboard development
- Supports multiple chart types
- Easy customization

Weaknesses [3]:

- Strictly dependent on the React framework
- Degraded performance with extremely large datasets
- Limited advanced customization for non-standard charts

2.4 Node.js

Node.js is a cross-platform runtime environment that allows JavaScript code to be executed on the server side [4]. In this project, Node.js provides the processing foundation for the entire backend system, distinguished by its non-blocking I/O architecture [4], [20]. This architecture enables the system to achieve high performance for web applications when concurrently processing security tasks without bottlenecks. Utilizing Node.js also synchronizes the JavaScript programming language across the development stack, making the development process seamless and optimizing the construction time for real-time applications and scalable backend services [20].

³ <https://medium.com/stackanatomy/charting-and-graphing-in-react-with-recharts-39409b4a865>



Figure 4: Node.js⁴

Strengths [4], [20]:

- Non-blocking I/O architecture
- High performance for web applications
- Large NPM ecosystem
- Supports real-time applications
- Uses JavaScript across the development stack
- Suitable for scalable backend services

Weaknesses [4], [20]:

- Less efficient for heavy CPU-intensive tasks
- Not ideal for CPU-intensive workloads
- Potential security risks from unmaintained third-party packages

2.5 NestJS

NestJS is a robust Node.js framework specifically designed for building scalable and maintainable server-side applications. NestJS provides a maintainable code structure based on modules, controllers, and services, featuring built-in dependency injection. Its native TypeScript support minimizes logic errors and enhances code strictness. This modular architecture is highly suitable for large applications, providing excellent support for REST APIs and WebSockets while ensuring easy testing and scalability [5].



Figure 5: NestJS⁵

Strengths [5], [21]:

- Modular architecture
- TypeScript support
- Built-in dependency injection
- Maintainable code structure
- Suitable for large applications

⁴ <https://pixabay.com/vi/images/search/node%20js/>

⁵ <https://en.wikipedia.org/wiki/NestJS>

- Supports REST APIs and WebSockets
- Easy testing and scalability

Weaknesses [5], [21]:

- Steep learning curve for advanced TypeScript concepts
- Overly complex structure for small and simple projects
- Slight performance overhead compared to lightweight frameworks

2.6 REST API

The REST API serves as the primary communication mechanism, securely routing data between the ReactJS frontend, the Node.js backend, AI services, and external systems. It is a simple, widely adopted, and platform-independent architecture that provides high flexibility during development. The scalable architecture of the REST API simplifies testing and maintenance, facilitates easy frontend-backend integration, and supports seamless integration with third-party services [6].

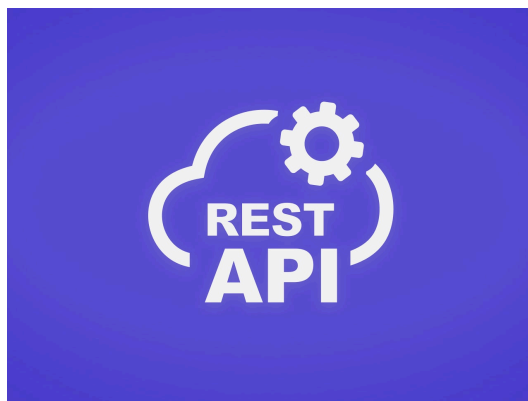


Figure 6: REST API⁶

Strengths [6]:

- Simple and widely adopted
- Platform-independent
- Easy frontend-backend integration
- Scalable architecture
- Easy to test and maintain
- Supports integration with third-party services

Weaknesses [6]:

- Prone to over-fetching and under-fetching of data
- Complex management of multiple resource endpoints
- Lack of native support for real-time data streaming

2.7 WebSocket

WebSocket is a communication protocol that provides continuous, bidirectional data transfer between the server and clients in real-time. Unlike traditional HTTP requests, WebSocket maintains an open connection with low latency. In this project, it can be used to instantly deliver AI anomaly alerts and security notifications. This reduces repeated HTTP requests and makes it highly efficient for live notifications and real-time dashboards [7].

⁶ <https://kodium.com/blog/building-elegant-rest-apis>



Figure 7: WebSocket⁷

Strengths [7]:

- Real-time communication
- Low latency
- Bidirectional data transfer
- Efficient for live notifications
- Suitable for real-time dashboards
- Reduces repeated HTTP requests

Weaknesses [7]:

- High infrastructure complexity for load balancing
- Requires manual logic for automatic reconnection
- High server resource consumption for concurrent open connections

2.8 PostgreSQL

PostgreSQL is an advanced, open-source relational database management system used to store structured business data, including users, assets, risks, incidents, policies, training records, and workflows. Meeting stringent requirements for data security, PostgreSQL delivers strong data integrity by supporting ACID transactions and providing strong security features. The platform is reliable and stable, offering advanced SQL capabilities and support for complex relationships, making it highly suitable for enterprise applications [8].



Figure 8: PostgreSQL⁸

Strengths [8]:

- Strong data integrity
- ACID transaction support

⁷ <https://en.wikipedia.org/wiki/Websocket>

⁸ <https://api.octoperf.com/doc/monitoring/create-connection/postgres/>

- Advanced SQL capabilities
- Supports complex relationships
- Reliable and stable
- Strong security features
- Suitable for enterprise applications

Weaknesses [24]:

- Higher resource consumption for simple read-heavy operations
- Complex configuration for high-availability scaling
- May require additional optimization for certain high-volume or specialized workloads

2.9 Elasticsearch

Elasticsearch is a highly powerful distributed search and analytics engine optimized for storing, searching, and analyzing large volumes of security log data [9]. This system excels in near real-time log processing and executing fast full-text searches. With its powerful filtering and aggregation capabilities, combined with horizontal scalability, Elasticsearch serves as an efficient search performance tool suitable for security log analysis [9], [25].



Figure 9: Elasticsearch⁹

Strengths [9], [25]:

- Fast full-text search
- Near real-time log processing
- Powerful filtering and aggregation
- Handles large volumes of data
- Horizontal scalability
- Suitable for security log analysis
- Efficient search performance

Weaknesses [9], [25]:

- High RAM and storage optimization requirements
- Lacks robust ACID transaction support for primary data storage
- Steep learning curve for distributed cluster management

2.10 Ollama

Ollama is an advanced platform that allows Large Language Models (LLMs) to be executed locally. In this project, it supports natural-language log analysis and the explanation of security log information. The core advantage of this local LLM execution is greater control over sensitive data, reducing the

⁹

<https://viblo.asia/p/gioi-thieu-ve-elastic-phan-1-gioi-thieu-co-ban-ve-elastic-search-va-huong-dan-cai-dat-co-ban-step-by-step-1VgZvNmZAw>

dependency on external AI APIs. Supporting multiple LLM models, Ollama is highly suitable for private environments where data privacy is a priority [10].



Figure 10: Ollama¹⁰

Strengths [10], [26]:

- Local LLM execution
- Greater control over sensitive data
- Reduced dependency on external AI APIs
- Supports multiple LLM models
- Suitable for private environments
- Useful for natural-language log analysis

Weaknesses [10], [26]:

- High hardware dependency for local execution
- Potential reasoning limitations compared to commercial cloud models
- High maintenance overhead for manual model updates

2.11 Docker

Docker is an essential containerization platform that packages applications together with their required dependencies into isolated and portable environments. In this project, Docker can be used to containerize the ReactJS frontend, NestJS backend, PostgreSQL database, Elasticsearch service, and other supporting services. This approach provides consistent development and deployment environments, simplifies application setup, and improves portability across different environments. It supports multi-container applications through Docker Compose, making it easier to deploy services and reducing environment-related configuration issues between team members [11].



Figure 11: Docker¹¹

Strengths [11]:

- Provides consistent development and deployment environments
- Simplifies application setup and configuration
- Isolates services and their dependencies
- Supports container-based deployment

¹⁰ <https://ollama.com/>

¹¹ <https://helpdesk.inet.vn/blog/Docker-la-gi-huong-dan-cai-dat-docker-cho-cac-he-dieu-hanh>

- Improves portability across different environments
- Supports multi-container applications through Docker Compose
- Makes it easier to deploy and manage frontend, backend, database, and supporting services
- Reduces environment-related configuration issues between team members

Weaknesses [27]:

- Complex inter-container networking and storage management
- Potential security vulnerabilities from container misconfigurations
- Slight performance overhead on non-Linux operating systems

3. Existing Systems

To identify useful features and design approaches for the proposed Enterprise Information Security Risk Management Platform with AI-based Anomaly Detection, several existing cybersecurity and GRC systems were reviewed. The selected systems provide useful references for risk management, compliance management, security monitoring, log analysis, incident detection, and security dashboards.

3.1 Eramba

3.1.1 Overview

Eramba (<https://www.eramba.org>) is a Governance, Risk, and Compliance (GRC) platform designed to help organizations manage information security governance activities in a centralized environment. It provides functions for risk management, compliance management, policy management, internal controls, incident management, awareness training, and reporting [14].

Eramba supports different types of compliance requirements, including cybersecurity frameworks such as ISO 27001 and NIST. Organizations can associate compliance requirements with internal controls, policies, projects, and other evidence to demonstrate their compliance status [14].

The system is particularly relevant to the proposed project because several of its GRC functions are similar to the planned modules, including asset-related risk management, policies, compliance controls, incident management, awareness training, notifications, activity logs, and reporting [14].

3.1.2 Illustration

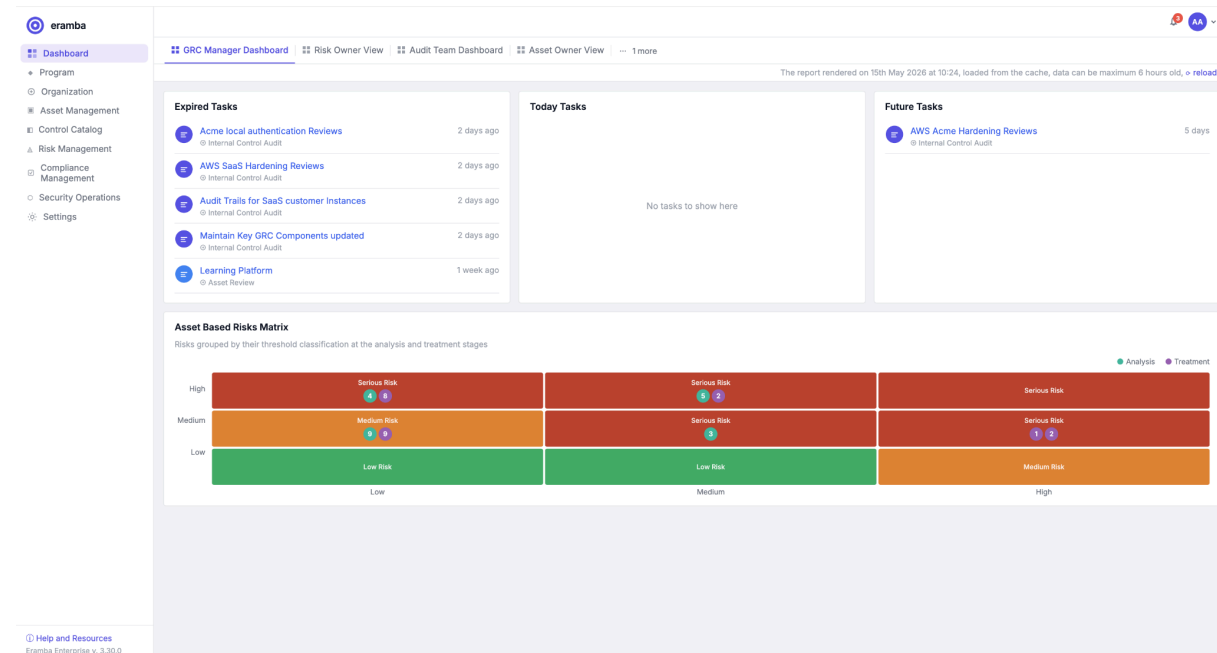


Figure 3.1. Eramba GRC Dashboard and Asset-Based Risk Matrix¹²

3.1.3 Advantages [14]

- Provides comprehensive GRC management functions in one system.
- Supports risk, compliance, policy, control, incident, and awareness management.
- Supports recognized frameworks such as ISO 27001 and NIST.
- Provides centralized management of GRC information.
- Supports reporting and dashboards for management purposes.
- Provides access-control mechanisms for different users.
- Includes activity logs and notification functions.
- Provides API and integration capabilities.
- Offers useful references for designing risk assessment and compliance workflows.

3.1.4 Disadvantages [14]

The platform is primarily focused on Governance, Risk, and Compliance management rather than real-time security-event monitoring.

It is not primarily designed as a SIEM platform for continuously collecting and analyzing endpoint and infrastructure security logs.

Behavioral anomaly detection is not the main focus of its GRC workflow.

Organizations still need additional security-monitoring solutions when they require continuous threat detection and detailed security-log analysis.

¹² <https://discussions.eramba.org/t/feature-different-dashboard-for-group/8668>

These limitations are important to the proposed project because the new system aims to combine traditional GRC functions with AI-based anomaly detection instead of operating them as separate solutions.

3.2 Wazuh

3.2.1 Overview

Wazuh (<https://wazuh.com>) is an open-source security platform providing Security Information and Event Management (SIEM) and Extended Detection and Response (XDR) capabilities [15]. It collects and analyzes security information from endpoints and other data sources to identify security threats and suspicious activities.

The Wazuh server analyzes data received from monitored agents and generates alerts when security threats are detected [15].

Wazuh can analyze logs generated by endpoints, network devices, and applications. Its log-analysis process enables threat detection, compliance auditing, troubleshooting, and identification of anomalous activities [15].

This makes Wazuh particularly relevant to the AI Anomaly Detection & Alert and System Log modules of the proposed system [15].

3.2.2 Illustration

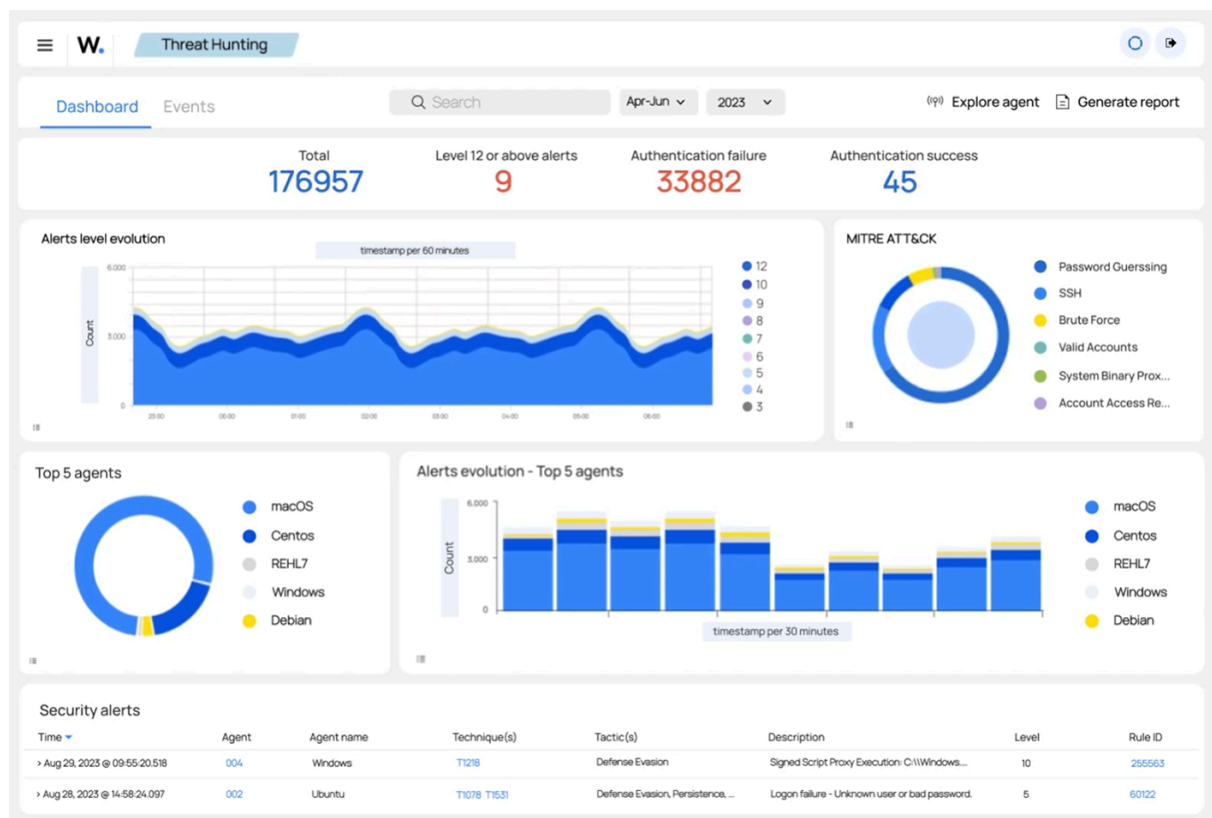


Figure 3.2. Wazuh Security Dashboard¹³

3.2.3 Advantages [15]

- Open-source security monitoring platform.

¹³ <https://wazuh.com/>

- Supports centralized collection and analysis of security logs.
- Provides near real-time security monitoring and alerting.
- Supports vulnerability detection.
- Provides File Integrity Monitoring.
- Supports threat hunting and malware detection.
- Provides dashboards for security analysts.
- Can handle data from multiple endpoints and security sources.
- Supports security-data searching, filtering, and investigation.
- Suitable as a reference for designing the log-monitoring and security-alert modules of the proposed system.

3.2.4 Disadvantages [15]

- Wazuh primarily focuses on security monitoring, threat detection, SIEM, and XDR capabilities rather than complete enterprise GRC management.
- It does not provide the same type of comprehensive risk-treatment workflow as a dedicated GRC platform.
- Policy lifecycle management and enterprise risk approval workflows are not its primary purpose.
- Business-oriented risk assessment, risk-treatment approval, awareness-training management, and executive GRC workflows require other tools or additional implementation.
- The amount of security data and alerts can make configuration and management more complex for organizations without dedicated security personnel.
- Therefore, Wazuh is a strong reference for the technical security-monitoring layer, but it does not fully address the governance and risk-management requirements targeted by the proposed system.

3.3 Splunk Enterprise Security

3.3.1 Overview

Splunk Enterprise Security (<https://www.splunk.com>) is a Security Information and Event Management (SIEM) solution designed to support security threat detection, investigation, and response. It enables organizations to collect and analyze security data from multiple sources, detect suspicious activities, investigate security events, and respond to potential threats [16].

Splunk provides powerful search and analytics capabilities for machine-generated data. Security teams can use the platform to analyze large volumes of logs, create dashboards, generate alerts, and investigate security incidents [16].

Splunk Enterprise Security also provides Risk-Based Alerting (RBA), which aggregates multiple risk events related to users, systems, or other entities and generates higher-level findings when defined risk conditions are met [16].

The system is relevant to the proposed project because its capabilities in security log analysis, risk-based alerting, behavior analytics, threat detection, and security dashboards provide useful references for designing the AI Anomaly Detection and Alert module [16].

3.3.2 Illustration

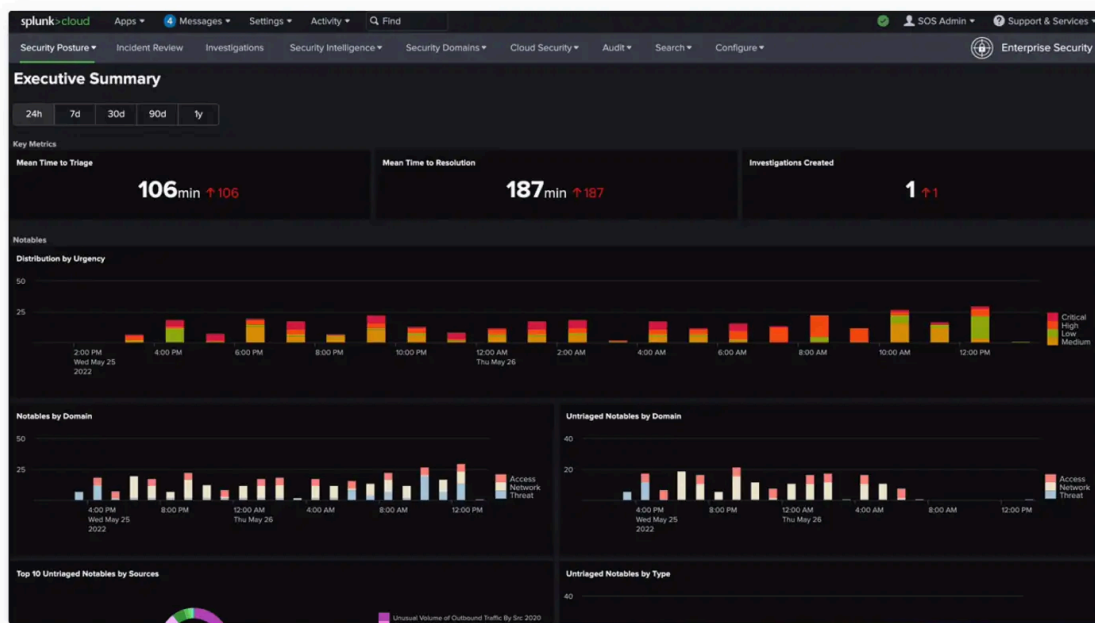


Figure 3.3. Splunk Enterprise Security Executive Summary Dashboard¹⁴

3.3.3 Advantages [16]

- Provides powerful SIEM capabilities for centralized security monitoring.
- Supports large-scale security log collection and analysis.
- Provides advanced threat detection and investigation capabilities.
- Supports Risk-Based Alerting to correlate multiple security events into higher-level risks.
- Provides behavior analytics and anomaly-related security capabilities.
- Supports real-time and historical security data analysis.
- Provides customizable security dashboards and reports.
- Supports threat intelligence and security-event correlation.
- Provides investigation and response workflows.
- Offers extensive integration capabilities for enterprise security environments.

3.3.4 Disadvantages [16]

- Splunk Enterprise Security is primarily designed for SIEM and security operations rather than complete Governance, Risk, and Compliance management.
- Enterprise GRC functions such as policy lifecycle management, organization-wide risk treatment plans, risk approval workflows, and security-awareness training are not its primary focus.
- Splunk uses commercial licensing models, and costs can increase depending on data ingestion volume or workload requirements.

¹⁴ https://www.splunk.com/en_us/solutions/security-monitoring.html

- Its broad enterprise security capabilities may require more configuration and specialized security knowledge compared with a smaller system designed specifically for SME requirements.

- Although Splunk provides advanced security analytics and AI-assisted functionality, explaining AI decisions and collecting analyst feedback specifically for continuous organization-specific anomaly-model retraining are not the same workflow proposed in this project.

Therefore, Splunk provides a strong reference for security log analytics, threat detection, risk-based alerting, and security dashboards, while the proposed system aims to connect these technical security-monitoring capabilities directly with GRC processes.

3.4 Comparison Summary

Capability	Eramba	Wazuh	Splunk ES	SecuraAI
GRC	Strong	Limited	Limited	Yes
Risk treatment workflow	Yes	No	Limited	Yes
Compliance	Yes	Partial	Partial	Yes
SIEM/log analysis	Limited	Yes	Yes	Partial/Integrated
Anomaly detection	Limited	Yes	Yes	Yes
Explainable AI	Not supported	Not supported	Partial	Yes
Analyst feedback loop for AI analysis	Not supported	Not supported	Partial	Yes
Awareness training	Yes	No	No	Yes
SME-oriented	N/A	N/A	N/A	Yes

Legend:

- *Yes: The capability is fully supported and integrated as a core feature of the platform.*
- *No / Not supported: The capability is not available natively within the system.*
- *Strong: The capability is a primary focus of the platform, offering comprehensive and advanced functionalities.*
- *Limited: The capability is available but lacks depth, or it requires significant manual effort/workarounds.*
- *Partial / Partial/Integrated: The system provides basic functionality or relies on external integrations to fulfill the capability.*
- *N/A (Not Applicable): The criterion does not align with the primary target audience or design philosophy of the system (e.g., enterprise-grade solutions inherently requiring high operational overhead, thus not SME-oriented).*

4. Business Opportunity

The primary target audience for this platform is Small and Medium-sized Enterprises (SMEs). These organizations need a practical, cost-effective solution to establish robust information security practices without the massive financial and human resource overhead typically required by large-scale corporate platforms [29]. However, SMEs are increasingly becoming the primary targets for cybercriminals, with recent data indicating that SMEs are increasingly targeted by cyberattacks

while often operating with limited cybersecurity resources [29]. Despite this growing threat, SMEs operate with limited resources and face a highly fragmented security management landscape. Currently, they are forced to use separate tools, creating a disconnect between governance policies and real-time technical monitoring. Traditional GRC-oriented platforms handle compliance well but lack active AI-based behavioral anomaly detection. Conversely, security monitoring platforms excel in log analysis but do not provide complete GRC workflows for managing organizational risks or approval processes. This fragmentation severely limits optimal resource utilization and makes risk assessment and incident response highly inefficient [14]–[16].

To address this critical market gap, SecuraAI delivers a unified Enterprise Information Security Risk Management Platform. The proposed system seamlessly integrates essential GRC management functions—including asset management, risk treatment, and compliance monitoring—with a built-in AI-based anomaly detection engine in a single, centralized web-based platform. This unified approach ensures that technical cybersecurity objectives strictly align with overarching business governance goals.

Centralizing these operations provides management with clearer visibility, facilitating better strategic decision-making and efficient resource allocation. The system significantly reduces manual log review and monitoring efforts. Furthermore, it accelerates incident response times by automatically generating draft incident records from confirmed AI alerts, helping SMEs proactively defend against threats while maintaining continuous business compliance.

Unlike existing solutions that focus solely on governance or purely on technical SIEM capabilities, SecuraAI bridges both domains specifically for SMEs. Its standout competitive advantage is the integration of Explainable AI (XAI) and an Analyst Feedback Loop. Rather than acting as a "black box," XAI provides clear, traceable logic behind every security alert—explaining exactly why a specific behavior or log was flagged [28]. This transparency can help analysts understand alert decisions and support audit-oriented investigation [28]. Analysts can then mark these alerts as correct or false positives, creating a continuous feedback loop that improves the anomaly detection model over time—delivering an advanced, tailored security capability that traditional platforms do not natively provide.

5. Software Product Vision

For small and medium-sized enterprises that need a centralized and practical way to manage information security risks, the proposed Enterprise Information Security Risk Management Platform with AI-based Anomaly Detection is a web-based system that integrates governance, risk, compliance, security incident management, and AI-assisted security monitoring in a single platform. Administrators can manage users, roles, permissions, system configurations, integrations, notifications, and audit logs; Security Officers can manage IT assets, assess and treat risks, manage policies and compliance controls, handle security incidents, conduct security awareness training, and review AI-generated anomaly alerts; Employees can report security incidents, acknowledge policies, participate in assigned training, and provide information about the assets under their responsibility; and Executives/Auditors can review risk information, approve risk treatment plans, monitor compliance evidence, and view management dashboards and reports. By combining these functions with AI-based anomaly detection, explainable AI, and analyst feedback, the system helps organizations detect suspicious activities earlier, reduce manual security monitoring, improve the consistency of risk and compliance processes, accelerate incident response, and provide management with clearer information for security-related decision-making.

6. Project Scope & Limitations

6.1 Major Features

FE-01: Authentication & Account Management: Login, logout, forgot/reset password, change password, MFA, and login history.

FE-02: User & Role Management: Add, edit, and disable users; assign roles; create custom roles; and configure permissions.

FE-03: IT Asset Management: Add, update, and delete assets; search and filter assets; classify assets; and assign asset owners.

FE-04: Risk Assessment & Treatment: Identify threats and vulnerabilities, calculate risk scores, propose treatment plans, visualize risks through a risk heat map, and track risk progress.

FE-05: Policy & Compliance Management: Create and update policies, assign policies, conduct compliance assessments, and manage compliance evidence.

FE-06: Security Incident Management: Report incidents, classify incident severity, assign incident handlers, and generate post-incident reports.

FE-07: AI-based Anomaly Detection & Alerting: Analyze logs and system behaviors, generate real-time alerts, provide Explainable AI, collect feedback through a feedback loop, and automatically create draft incident records.

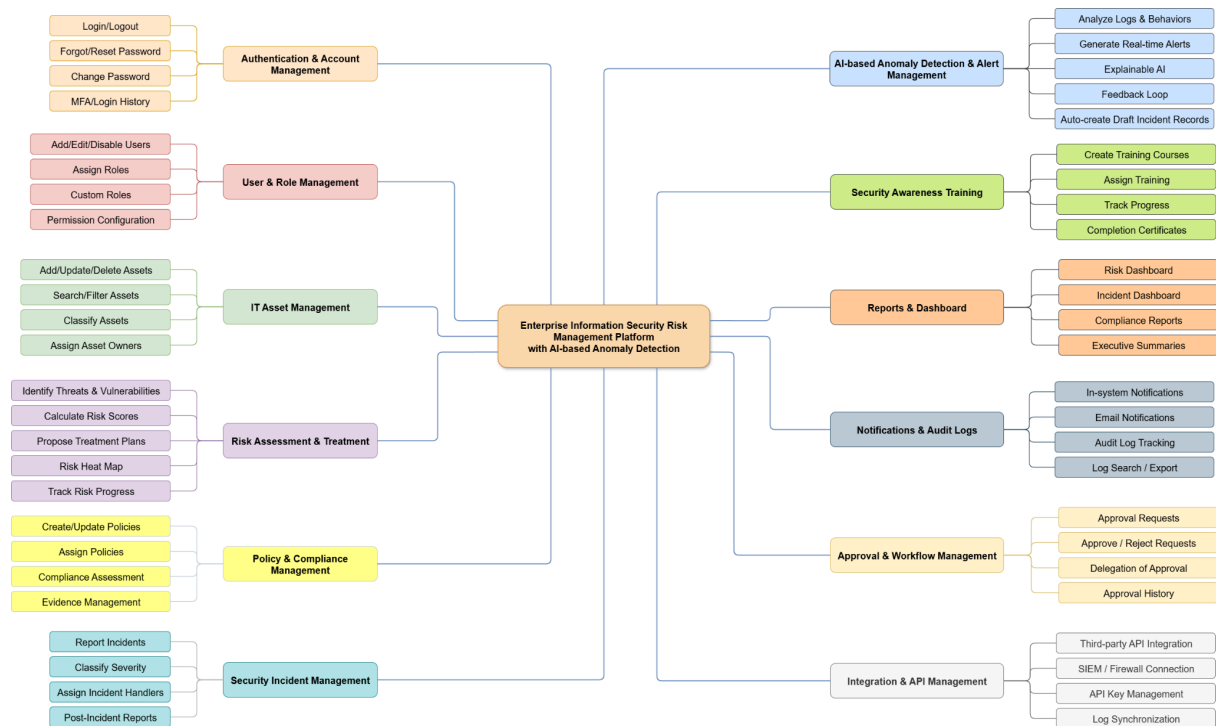
FE-08: Security Awareness Training: Create training courses, assign training, track learner progress, and issue completion certificates.

FE-09: Reports & Dashboard: Provide risk dashboards, incident dashboards, compliance reports, and executive summaries.

FE-10: Notifications & Audit Logs: Send in-system and email notifications, track audit logs, and support log searching and exporting.

FE-11: Approval & Workflow Management: Submit approval requests, approve or reject requests, delegate approval authority, and track approval history.

FE-12: Integration & API Management: Support third-party API integration, SIEM and firewall connections, API key management, and log synchronization.



6.2 Limitations & Exclusions

LI-01: No Third-party Authentication: Users can only log in using accounts created or provided by the system administrator. Authentication through third-party providers such as Google, Facebook, Microsoft, or other social login services is not supported.

LI-02: Web-based Platform Only: The system is developed as a web-based application. Native mobile applications for Android and iOS are not included within the scope of this project.

LI-03: AI Provides Decision Support, Not Autonomous Response: The AI module is used to detect abnormal activities, calculate risk levels, generate alerts, and provide explanations. It does not automatically block users, disable accounts, isolate devices, or perform other security-response actions without review and confirmation from an authorized Security Officer.

LI-04: Not a Full SIEM or Endpoint Security Replacement: The system does not aim to completely replace dedicated SIEM, XDR, firewall, antivirus, or endpoint detection and response solutions. External security systems may provide logs or security data to the platform through supported integrations.

LI-05: Limited External System Integration: Integration is limited to supported APIs and configured log sources implemented within the project scope. The system does not guarantee direct integration with every third-party SIEM, firewall, security product, or enterprise application.

LI-06: Limited Compliance Framework Coverage: Compliance management primarily focuses on the information security frameworks selected for the project, such as ISO 27001 and NIST. Full implementation of every international, industry-specific, or national regulatory framework is outside the project scope.

LI-07: AI Detection Depends on Available Log Data: The effectiveness of anomaly detection depends on the availability, quality, and amount of security log and behavioral data provided to the AI model. The system cannot guarantee detection of every security threat, previously unseen attack, or abnormal activity.

7. References

- [1] React, "React Documentation." [Online]. Available: <https://react.dev/>. [Accessed: Aug. 26, 2026].
- [2] Tailwind Labs, "Tailwind CSS Documentation." [Online]. Available: <https://tailwindcss.com/docs>. [Accessed: Aug. 26, 2026].
- [3] Recharts, "Recharts: A Composable Charting Library Built on React Components." [Online]. Available: <https://recharts.org/>. [Accessed: Aug. 26, 2026].
- [4] OpenJS Foundation, "Node.js Documentation." [Online]. Available: <https://nodejs.org/>. [Accessed: Aug. 26, 2026].
- [5] NestJS, "NestJS Documentation." [Online]. Available: <https://docs.nestjs.com/>. [Accessed: Aug. 26, 2026].
- [6] R. T. Fielding, "Architectural Styles and the Design of Network-based Software Architectures," Ph.D. dissertation, Dept. Information and Computer Science, University of California, Irvine, CA, USA, 2000. [Online]. Available: <https://www.ics.uci.edu/~fielding/pubs/dissertation/top.htm>. [Accessed: Aug. 26, 2026].
- [7] I. Fette and A. Melnikov, "The WebSocket Protocol," Internet Engineering Task Force, RFC 6455, Dec. 2011. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6455>. [Accessed: Aug. 26, 2026].
- [8] PostgreSQL Global Development Group, "PostgreSQL Documentation." [Online]. Available: <https://www.postgresql.org/docs/>. [Accessed: Aug. 26, 2026].
- [9] Elastic, "Elasticsearch Documentation." [Online]. Available: <https://www.elastic.co/docs>. [Accessed: Aug. 26, 2026].
- [10] Ollama, "Ollama Documentation." [Online]. Available: <https://docs.ollama.com/>. [Accessed: Aug. 26, 2026].
- [11] Docker, "Docker Documentation." [Online]. Available: <https://docs.docker.com/>. [Accessed: Aug. 26, 2026].
- [12] International Organization for Standardization, "ISO/IEC 27001:2022 — Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Requirements," 2022. [Online]. Available: <https://www.iso.org/standard/27001>. [Accessed: Aug. 26, 2026].
- [13] National Institute of Standards and Technology, "The NIST Cybersecurity Framework (CSF) 2.0," NIST CSWP 29, Gaithersburg, MD, USA, Feb. 2024. doi: 10.6028/NIST.CSWP.29.
- [14] Eramba, "Eramba: Open Source GRC and Compliance Software." [Online]. Available: <https://www.eraamba.org/>. [Accessed: Aug. 26, 2026].
- [15] Wazuh, "Wazuh Documentation." [Online]. Available: <https://documentation.wazuh.com/current/>. [Accessed: Aug. 26, 2026].
- [16] Splunk Inc., "Splunk Enterprise Security." [Online]. Available: https://www.splunk.com/en_us/products/enterprise-security.html. [Accessed: Aug. 26, 2026].
- [17] React, "memo – React." [Online]. Available: <https://react.dev/reference/react/memo>. [Accessed: Aug. 26, 2026].

- [18] Tailwind Labs, "Detecting Classes in Source Files." [Online]. Available: <https://tailwindcss.com/docs/detecting-classes-in-source-files>. [Accessed: Aug. 26, 2026].
- [19] Recharts, "Recharts: A Composable Charting Library Built on React Components." [Online]. Available: <https://recharts.org/>. [Accessed: Aug. 26, 2026].
- [20] OpenJS Foundation, "Don't Block the Event Loop (or the Worker Pool)." [Online]. Available: <https://nodejs.org/en/learn/asynchronous-work/dont-block-the-event-loop>. [Accessed: Aug. 26, 2026].
- [21] NestJS, "Request Lifecycle." [Online]. Available: <https://docs.nestjs.com/faq/request-lifecycle>. [Accessed: Aug. 26, 2026].
- [22] M. Stowe, Undisturbed REST: A Guide to Designing the Perfect API. San Francisco, CA, USA: MuleSoft, 2015.
- [23] I. Fette and A. Melnikov, "The WebSocket Protocol," Internet Engineering Task Force, RFC 6455, Dec. 2011. [Online]. Available: <https://www.rfc-editor.org/rfc/rfc6455>. [Accessed: Aug. 26, 2026].
- [24] PostgreSQL Global Development Group, "High Availability, Load Balancing, and Replication." [Online]. Available: <https://www.postgresql.org/docs/current/high-availability.html>. [Accessed: Aug. 26, 2026].
- [25] Elastic, "Tune for Search Speed." [Online]. Available: <https://www.elastic.co/docs/deploy-manage/production-guidance/optimize-performance/search-speed>. [Accessed: Aug. 26, 2026].
- [26] Ollama, "Hardware Support." [Online]. Available: <https://docs.ollama.com/gpu>. [Accessed: Aug. 26, 2026].
- [27] Docker, "Docker Engine Security." [Online]. Available: <https://docs.docker.com/engine/security/>. [Accessed: Aug. 26, 2026].
- [28] N-iX, "Explainable AI in cybersecurity: How it works and why it matters," 2026. [Online]. Available: <https://www.n-ix.com/explainable-ai-in-cybersecurity/>. [Accessed: Aug. 26, 2026].
- [29] SME Communities, "Why SMEs Must Integrate Cybersecurity with GRC," [Online]. Available: <https://smecommunities.com/why-smes-must-integrate-cybersecurity-with-grc/>. [Accessed: Aug. 26, 2026].
- [30] SME Communities, "Why SMEs Must Integrate Cybersecurity with GRC." [Online]. Available: <https://smecommunities.com/why-smes-must-integrate-cybersecurity-with-grc/>. [Accessed: Aug. 26, 2026].